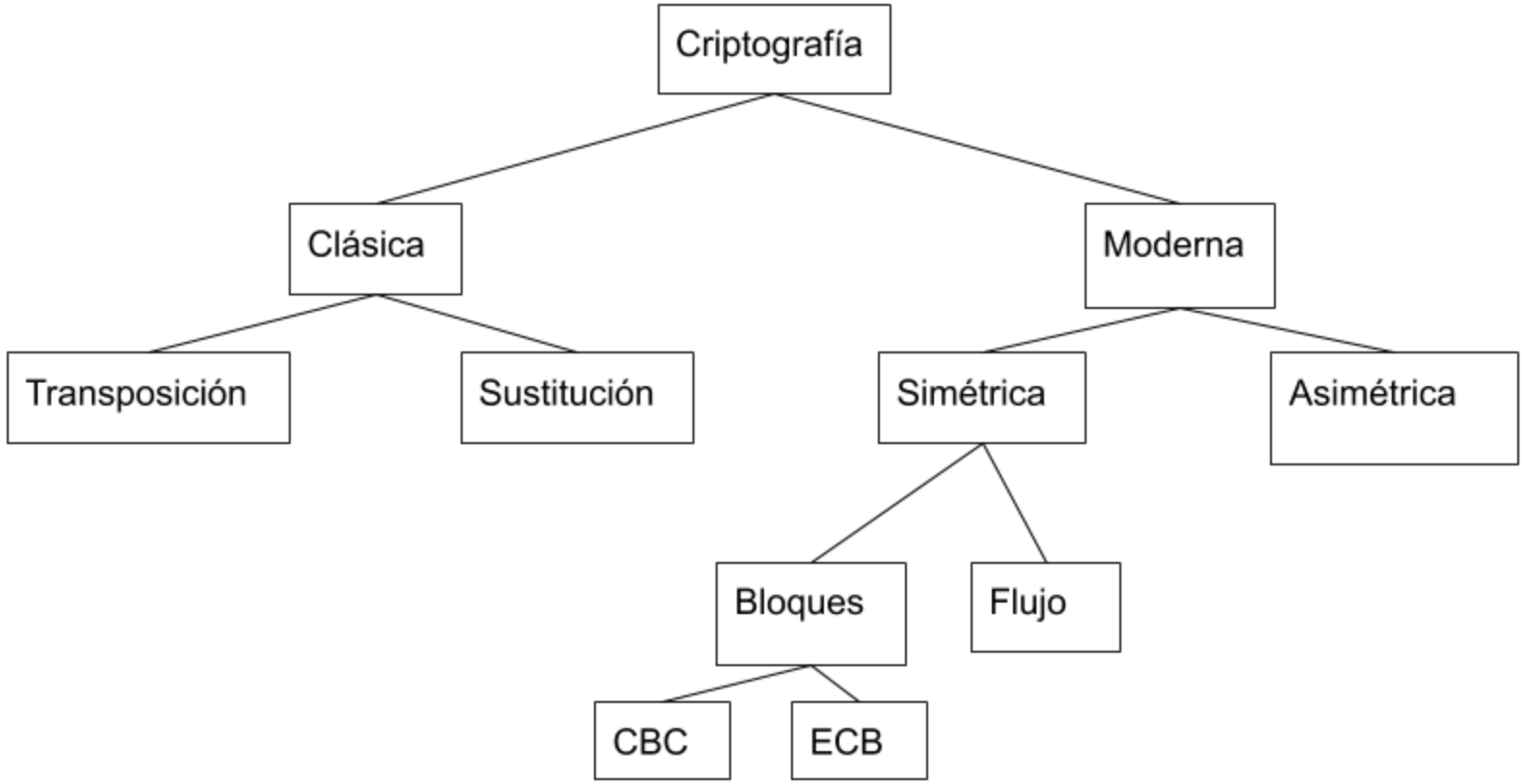
IC

Criptografía Asimetrica

Criptografía Moderna



Sistemas de criptografía

Existen dos tipos básicos de criptosistemas modernos:

> - **Sistemas de cifrado simétrico** (también conocidos como sistemas de clave secreta o clave privada)
> - **Sistemas de cifrado asimétrico** (también conocidos como sistemas de clave pública)

> Un concepto muy importante utilizado en criptografía moderna es el de las funciones de HASH.

Criptografia Asimetrica

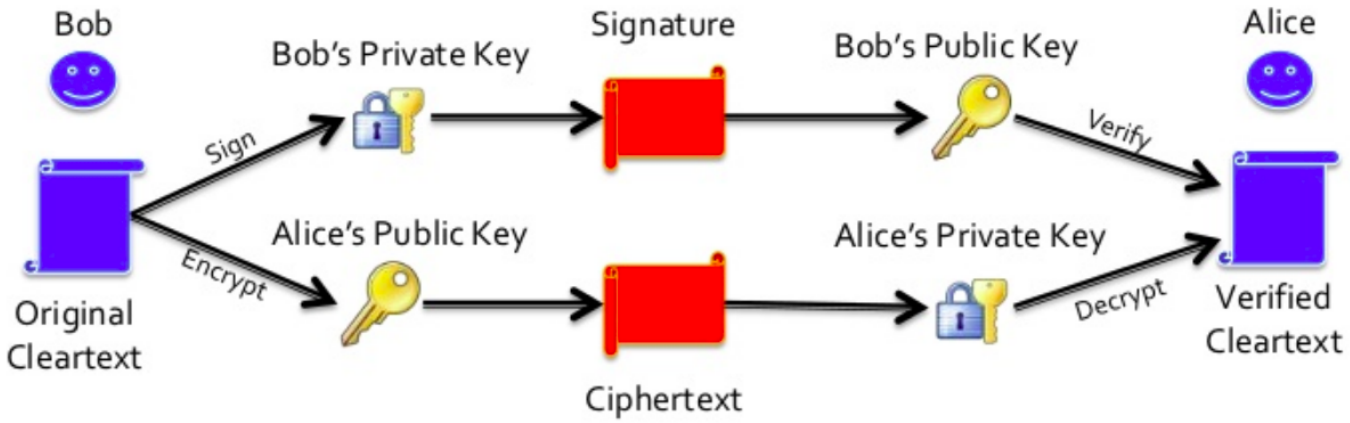
Es un sistema de cifrado que utiliza dos claves (matemáticas relacionadas) conocidas como la clave pública y la privada:

- La clave pública está disponible para todos
- La clave privada es conocida sólo por el individuo dueño del par de claves

Uso de las claves

- Las claves están matemáticamente relacionadas entre sí
- Ambas claves pueden ser usadas para encriptar y desencriptar
  - Lo que una hace, la otra lo deshace
- Dependiendo de como se usen estaremos usando un modo de operación determinado:
  - autenticación
  - encripción

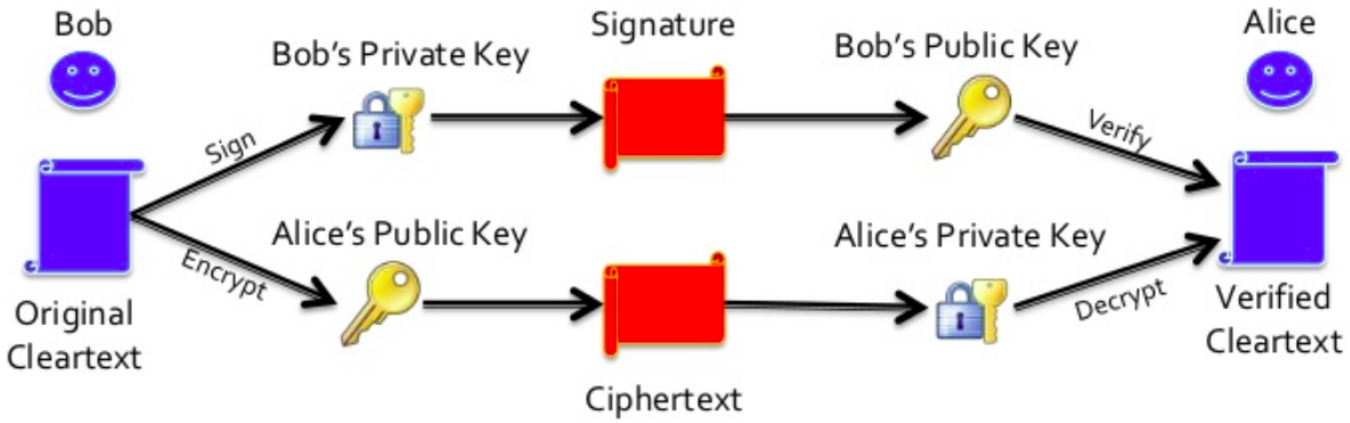
Modo autenticación (Sign)



- El emisor cifra el mensaje con su clave privada
- Los destinatarios descifran usando la clave pública del emisor

```
Garantiza autenticidad, integridad y no repudio.
```

Modo encripción (Encrypt)

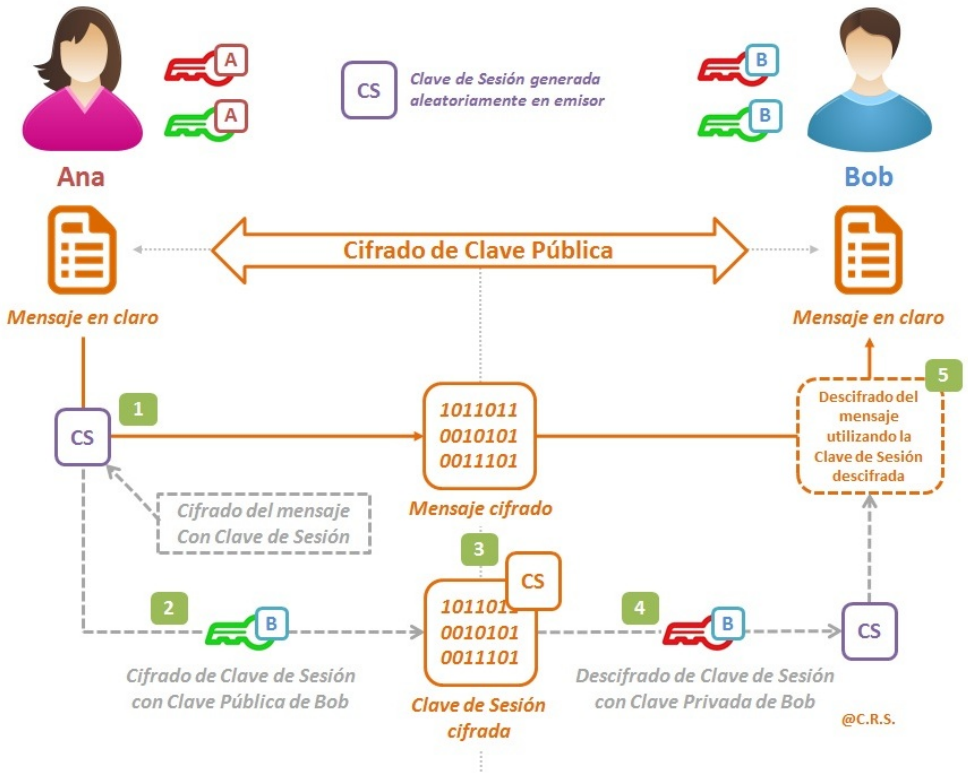


- El emisor cifra el mensaje con la clave pública del receptor
- El receptor desencripta usando su clave privada

```
Garantiza confidencialidad
```

Ventajas Cifrado asimétrico

- No es necesario efectuar ningún intercambio de claves secretas.
- A través de sus distintos modos de uso se cubre gran parte de los requisitos de seguridad de la información: Firma / Cifrado / Firma + Cifrado



Criptografia Simétrica

- Es necesario compartir claves por medios no seguros
- No permite garantizar la seguridad del modo autenticación
- No resulta adecuado para comunicaciones seguras de uno a muchos (grupos)
  Elevado numero de claves a manejar

Criptografia Asimétrica

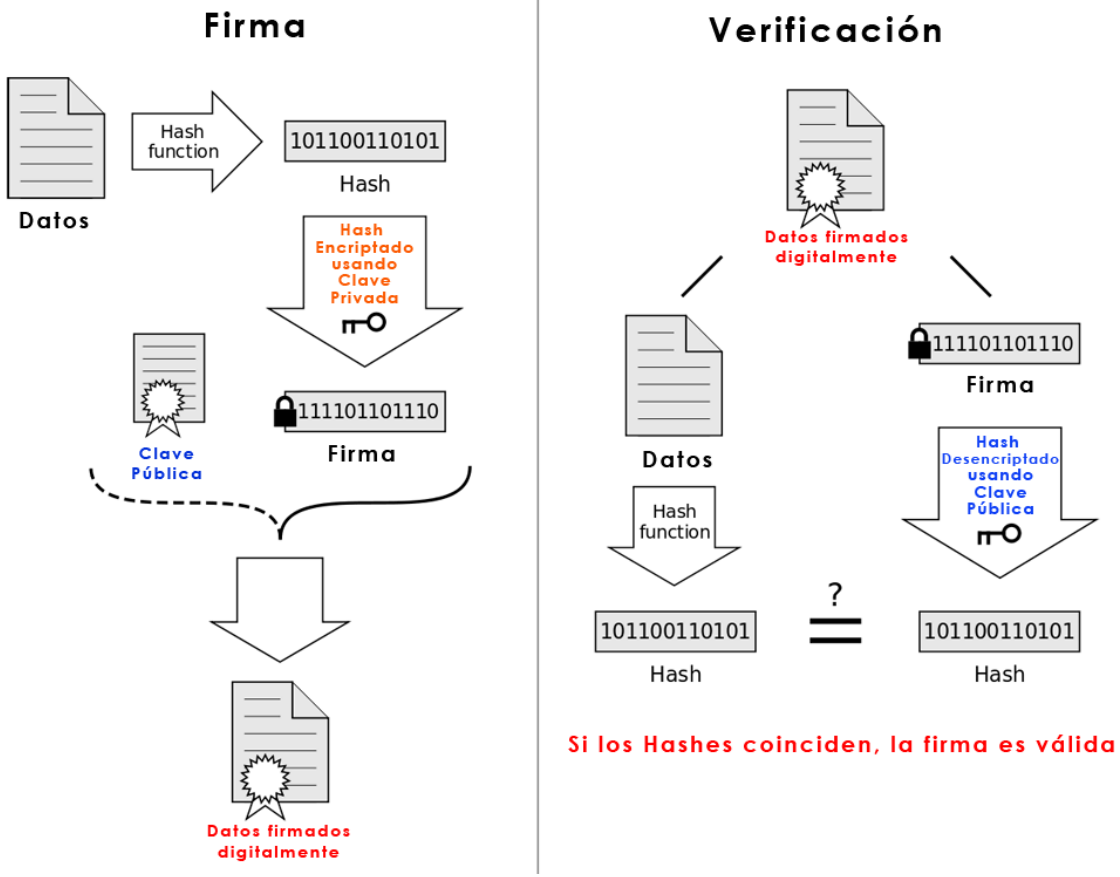
- No es necesario intercambio de claves seguro
- Permite garantizar la seguridad del modo autenticación
  - Permite Firmar digitalmente documentos
- Resulta adecuado para comunicaciones seguras de uno a muchos (grupos)

Ejemplos de algoritmos

- Diffie-Hellman - Logaritmo discreto - Pionero de la criptografía de clave pública en 1976, diseñado para acordar una clave secreta a través de un canal inseguro
- RSA - Factorizacion de numeros primos - Lanzado en 1977, revolucionó el campo al permitir tanto el cifrado de datos como la firma digital
- ElGamal - Logaritmo discreto - Firma y cifrado
- DSA - Logaritmo discreto - Solo firma digital
- CCE - Logaritmo discreto en curvas elipticas

Firma digital

Garantiza integridad y no-repudio en origen del mensaje



Firma digital

- Utiliza el modo autenticación
- Asocia un documento digital con su autor.
    - El emisor genera la firma digital usando su clave privada para cifrar el hash del mensaje a firmar
    - El receptor puede verificar la firma comparando:
        - El hash obtenido al descifrar con la clave pública del emisor la firma digital
        - El resultado del hashear el mensaje recibido

> En RSA la firma es el HASH del mensaje cifrado con la privada del emisor

¿Qué necesito para firmar?

> Para firmar digitalmente un documento, necesito tener un par de claves (una pública y una privada) para poder usar el modo autenticación de la criptografía asimetrica

Pero, en realidad ....

> no hay garantias sobre **CUAL ES** la clave privada de **UNA PERSONA** en particular

¿Qué necesito para firmar?

- Un par de claves (una pública y una privada)
- Un certificado digital que asocie al firmante con su clave pública
  Aparece el concepto de Autoridad de Certificación

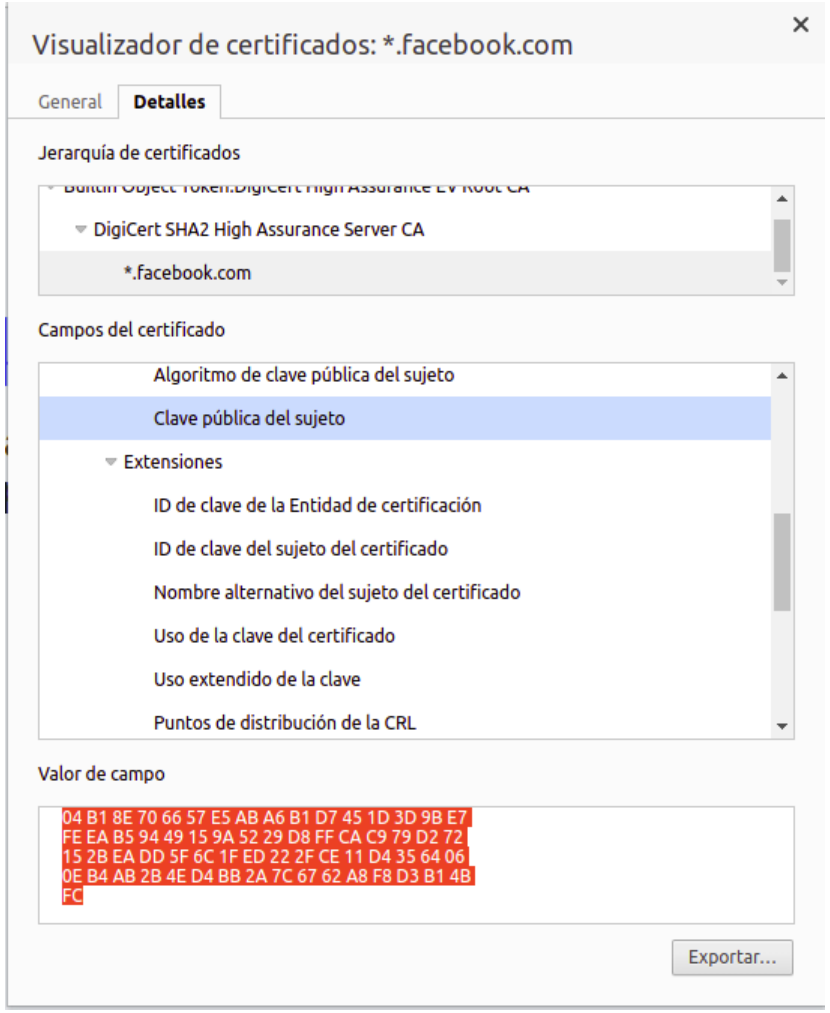
Certificado digital

- El certificado digital es una estructura de datos que contiene:
  - La identidad del poseedor
  - La clave pública del poseedor
  - Período de validez del certificado
  - Identidad del emisor del certificado
  - Firma digital (emitida el emisor del certificado)



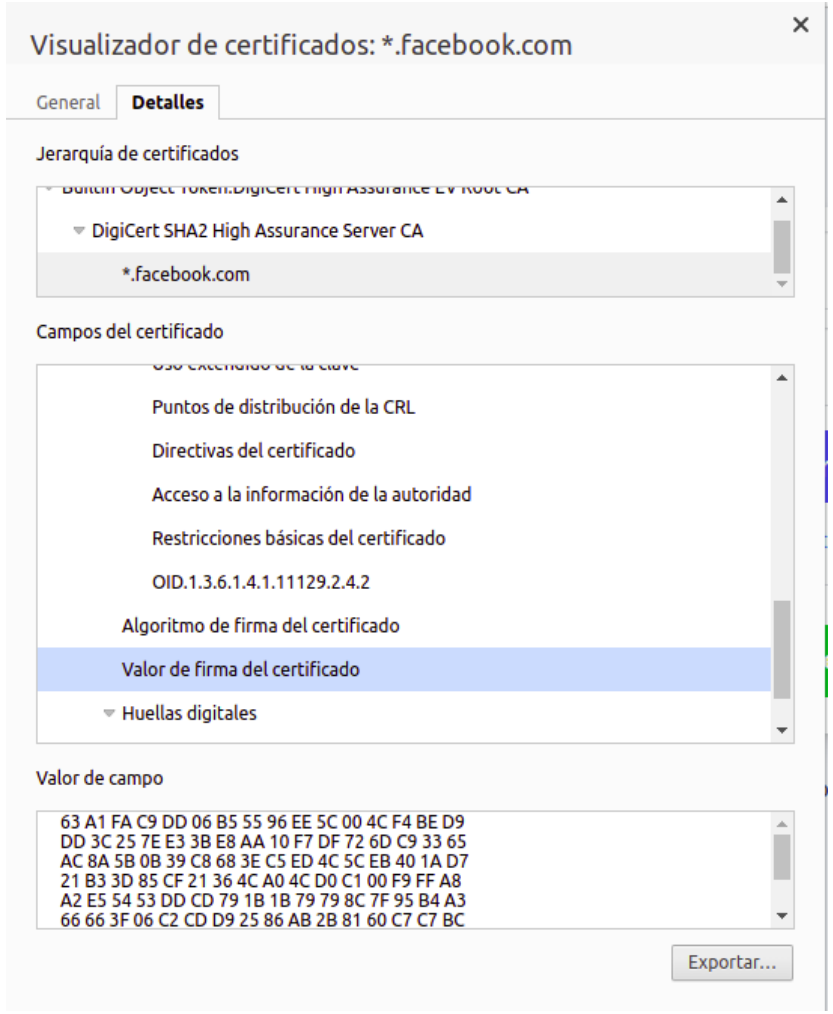
Certificado digital

- El certificado digital es una estructura de datos que contiene:
  - La identidad del poseedor
  - La clave pública del poseedor
  - Período de validez del certificado
  - Identidad del emisor del certificado
  - Firma digital (emitida el emisor del certificado)



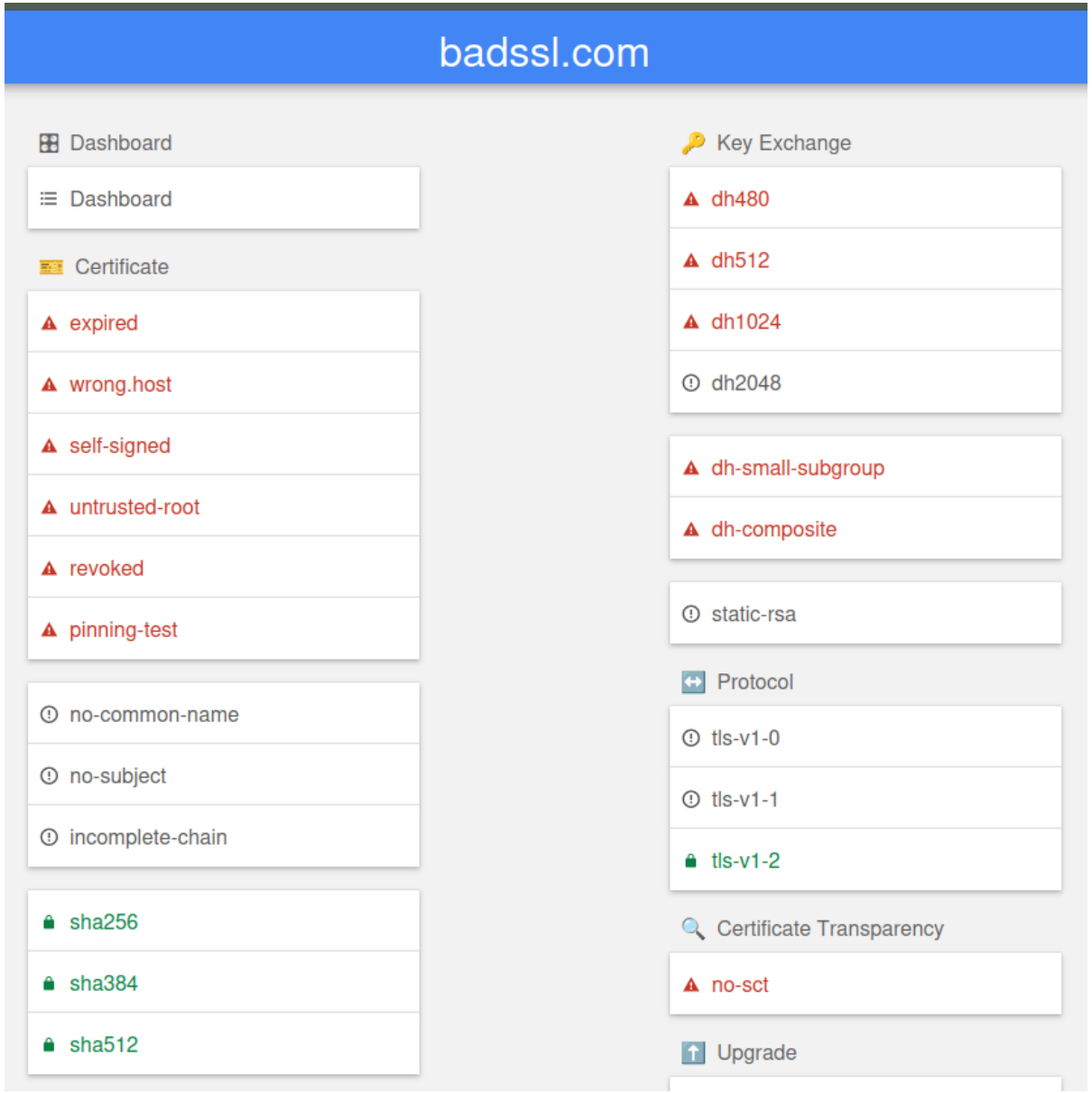
Certificado digital

- El certificado digital es una estructura de datos que contiene:
  - La identidad del poseedor
  - La clave pública del poseedor
  - Período de validez del certificado
  - Identidad del emisor del certificado
  - Firma digital (emitida el emisor del certificado)



Errores en certificados en HTTPs

- En https://badssl.com/ podemos ver distintos ejemplos de problemas con certificados:
  - expired
  - wrong host
  - self signed
  - untrusted root
  - revoked
  - mixed content



Usos prácticos / protocolos

- Infraestructura de Clave Pública (PKI):
  - Certificados digitales TLS: **por ejemplo los usados en HTTPs**
  - Certificados personales para encripción y firma digital
- PGP (esquema de confianza descentralizado)
  - Certificados personales para encripción y firma digital

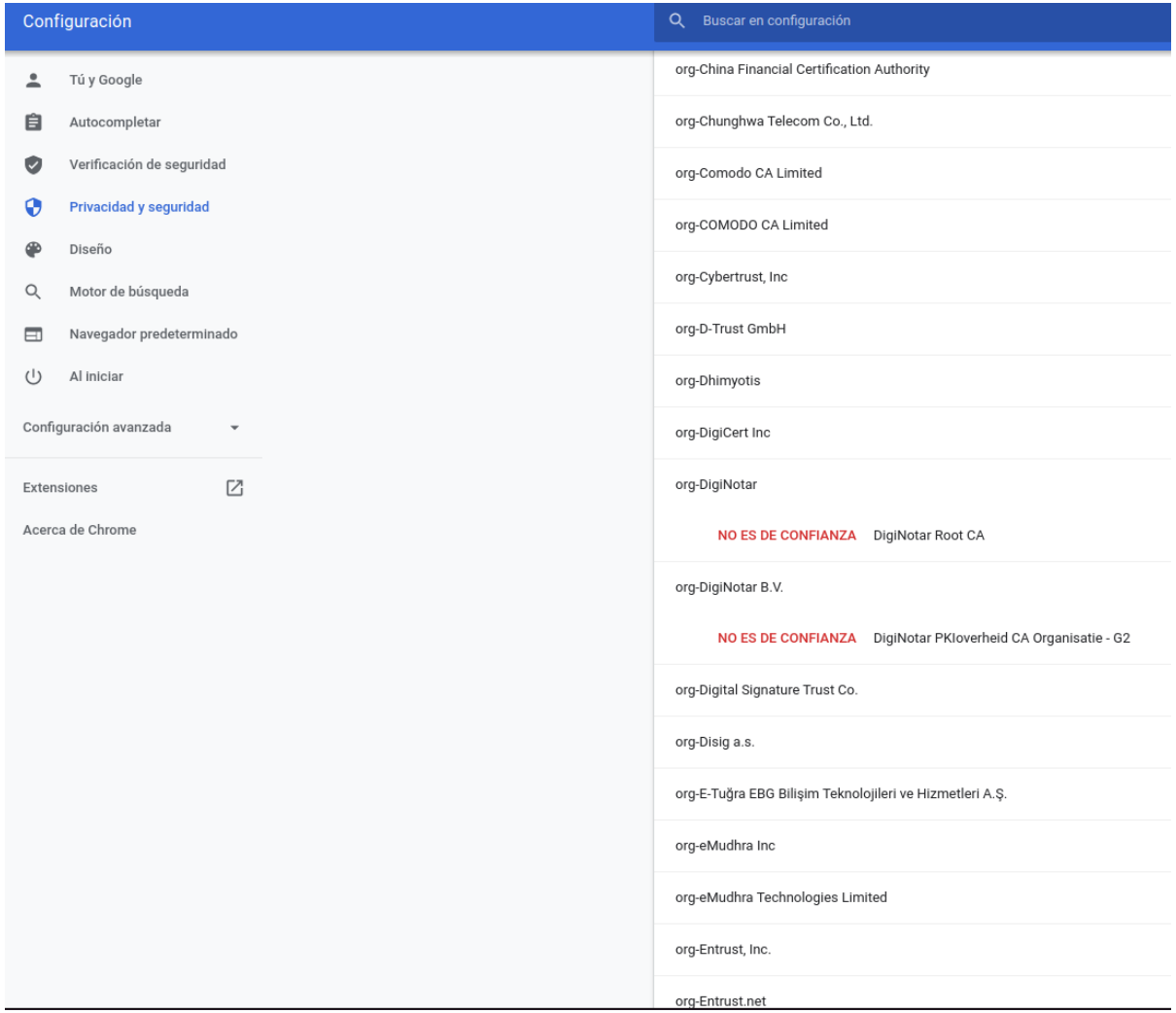
PKI – Infraestructura de clave pública

- Es la infraestructura encargada del manejo de certificados digitales.
- Su objetivo consiste en emitir y gestionar certificados digitales X.509 que asocian el par de claves a su poseedor.
- La confianza se basada en la confianza que le damos a determinados organismos conocidos como autoridades de certificación.
- Ejemplos de **CAs** o **Certification Authorities**: Let's Encrypt, DigiCert, Sectigo, GlobalSign, etc

Sobre las autoridades de certificación

- Son las que **EMITEN** los certificados digitales de los diferentes sitios web que usamos a diario
- Los navegadores **CONFIAN** en cualquier certificado firmado por una autoridad de certificación
- El certificación de una **AUTORIDAD DE CERTIFICACION** está autofirmado por ellas mismas

¿Cuáles son las autoridades de certificacion en las que confiamos?



Problema conocido con una autoridad de certificación

DigiNotar

From Wikipedia, the free encyclopedia

DigiNotar was a Dutch certificate authority owned by VASCO Data Security International, Inc.[1][2] On September 3, 2011, after it had become clear that a security breach had resulted in the fraudulent issuing of certificates, the Dutch government took over operational management of DigiNotar's systems.[3] That same month, the company was declared bankrupt.[4]

An investigation into the hacking by Dutch-government appointed Fox-IT consultancy identified 300,000 Iranian Gmail users as the main target of the hack (targeted subsequently using man-in-the-middle attacks), and suspected that the Iranian government was behind the hack.[5] While nobody has been charged with the break-in and compromise of the certificates (as of 2013), cryptographer Bruce Schneier says the attack may have been "either the work of the NSA, or exploited by the NSA."[6] However, this has been disputed, with others saying the NSA had only detected a foreign intelligence service using the fake certificates.[7] The hack has also been claimed by the so-called Comodohacker, allegedly a 21-year-old Iranian student, who also claimed to have hacked four other certificate authorities, including Comodo, a claim found plausible by F-Secure, although not fully explaining how it led to the subsequent "widescale interception of Iranian citizens".[8]

After more than 500 fake DigiNotar certificates were found, major web browser makers reacted by blacklisting all DigiNotar certificates.[9] The scale of the incident was used by some organizations like ENISA and AccessNow.org to call for a deeper reform of HTTPS in order to remove the weakest link possibility that a single compromised CA can affect that many users.[10][11]

Contents [hide]

1 Company
- 1.1 History
- 1.2 Bankruptcy
- 1.3 Refusal to publish report

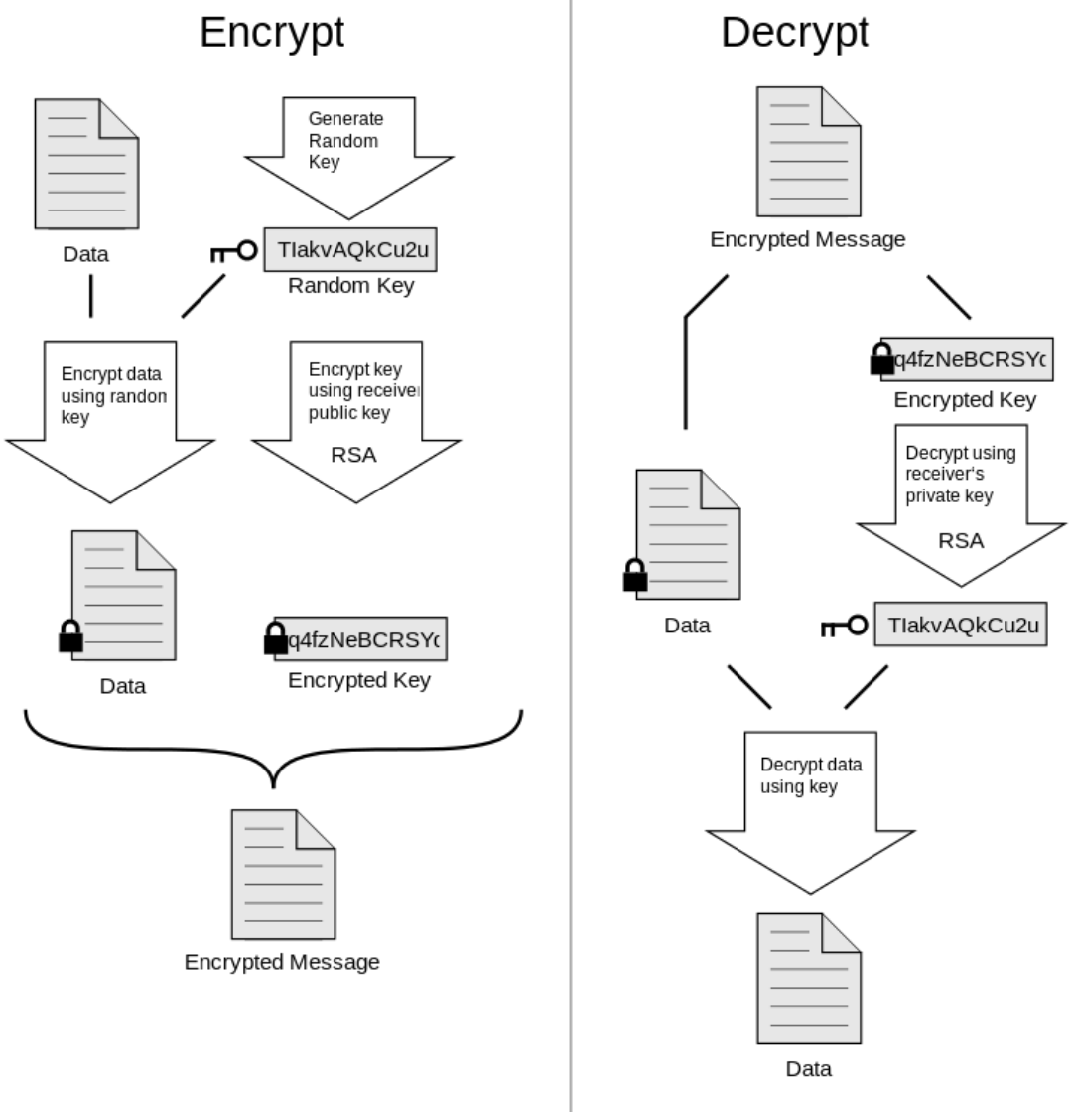
2 Issuance of fraudulent certificates
- 2.1 Steps taken by the Dutch government

3 See also
4 References
5 Further reading
6 External links

PGP (Pretty Good Privacy)

- Podemos usar PGP de manera personal tanto para cifrar como para firmar documentos
- PGP permite utilizar tanto criptografia simetrica como asimétrica
- En **PGP** cada usuario en PGP es su propia Autoridad (Es un sistema descentralizado)
    - En PGP, una clave es válida si yo mismo la firmé
- Alternativamente, se pueden manejar otros esquemas de confianza:
    - Puedo confiar en lo que otro usuario firme.
    - Puedo manejar otros esquemas de confianza con multiples firmas

PGP criptosistema de cifrado híbrido.



Resumen Redes de confianza

- PKI provee un esquema centralizado de confianza en el que confiamos ciegamente en una serie de autoridades de certificación
- PGP provee un esquema descentralizado de confianza en el que no hay autoridades de certificación
    - En PGP cada individuo es su propia CA.
    - Cada individuo es responsable de certificar/firmar lo que considere.

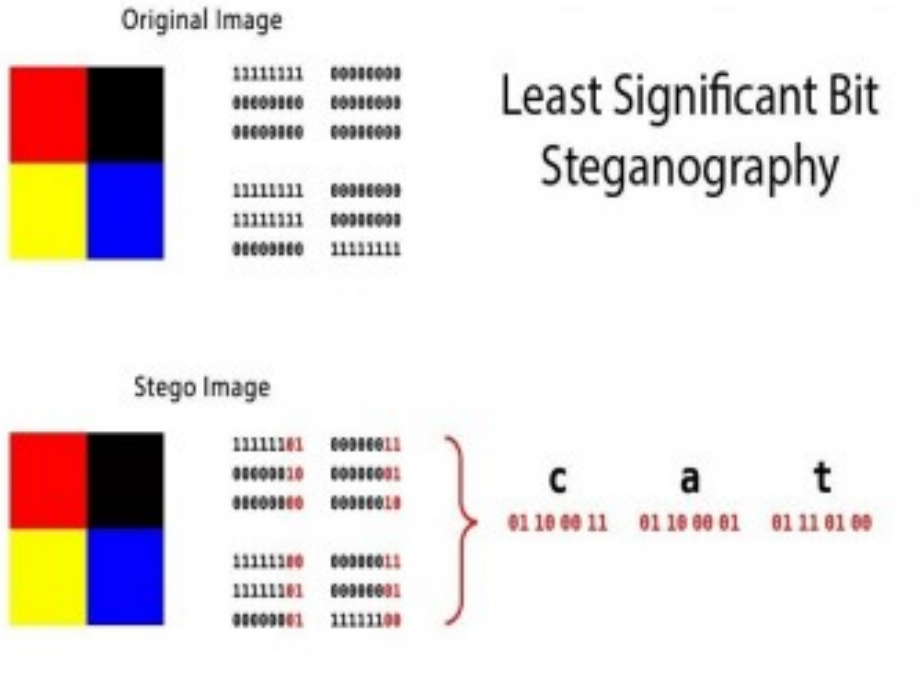
Esteganografía

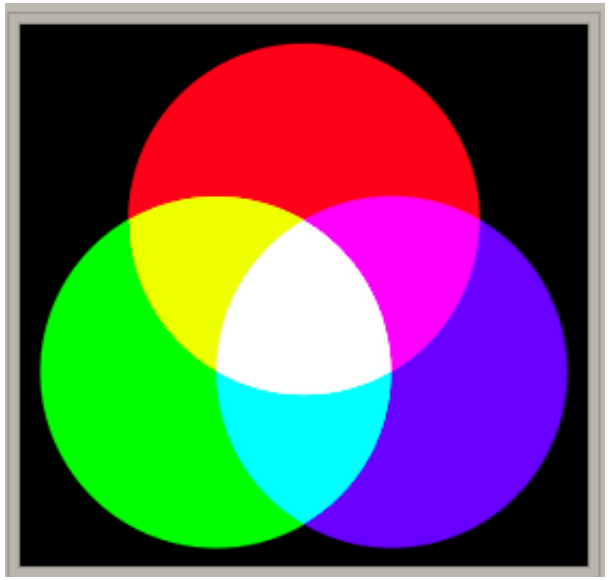
- Técnica para ocultar un mensaje secreto dentro de un mensaje ordinario y extraerlo en el destino para mantener la confidencialidad de los datos
- Arte de ocultar un archivo de texto, imagen, video o audio dentro de otro archivo, llamado portador, de modo que no sea perceptible su existencia
- El objetivo principal es ocultar la información lo suficientemente bien como para que los destinatarios involuntarios no sospechen que el medio esteganográfico contiene datos ocultos
- Los medios portadores preferidos (por sus características) son archivos multimedia (imágenes, audio y vídeo).

Esteganografía - Tipos

- **Pura**: En esta estrategia se supone que el mensaje pasa inadvertido ante miradas ajenas. La seguridad del mensaje está basada en la oscuridad
- **De clave secreta**: El estegoalgoritmo se parametriza con una clave, que además de ocultar el mensaje, lo cifra

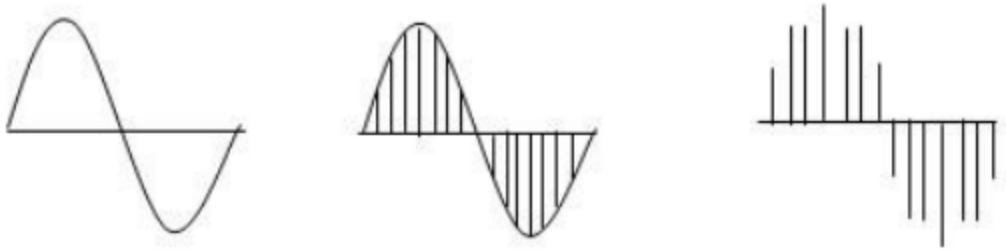
Ejemplo: Stego en imagenes, LSB usando la paleta RGB





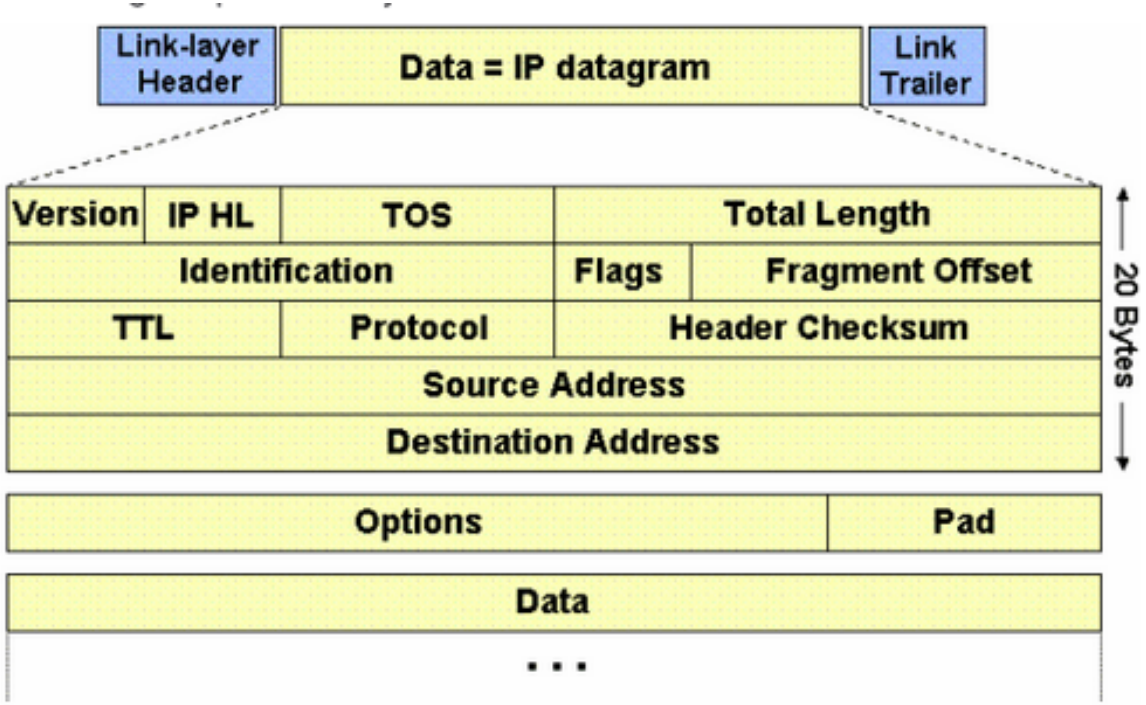
Ejemplo 2: Stego en audio, LSB

- Proceso de digitalización:



Flujo de audio	"A" en binario	Flujo de audio con el mensaje oculto
1001 1000 0011 1100	**0**	1001 1000 0011 110**0**
1101 1011 0011 1000	**1**	1101 1011 0011 100**1**
1011 1100 0011 1101	**1**	1011 1100 0011 110**1**
1011 1111 0011 1100	**0**	1011 1111 0011 110**0**
1011 1010 0111 1111	**0**	1011 1010 0111 111**0**
1111 1000 0011 1100	**1**	1111 1000 0011 110**1**
1101 1100 0111 1000	**0**	1101 1100 0111 100**0**
1000 1000 0001 1111	**1**	1000 1000 0001 111**1**

Ejemplo 3: Stego en red



- Conocido como cover channel o canal encubierto
- Pueden usarse distintos protocolos como por ejemplo: IP, ICMP, DNS, etc.